Threat Research & Intelligence (https://blog.sekoia.io/category/threat-research/)

Active Lycantrox infrastructure illumination

Sekoia.io is actively monitoring hundreds of malicious infrastructure clusters to protect its customers. In light of the recent Citizenlab blogspot and in solidarity with the efforts against cyber mercenaries, we have chosen to shed...

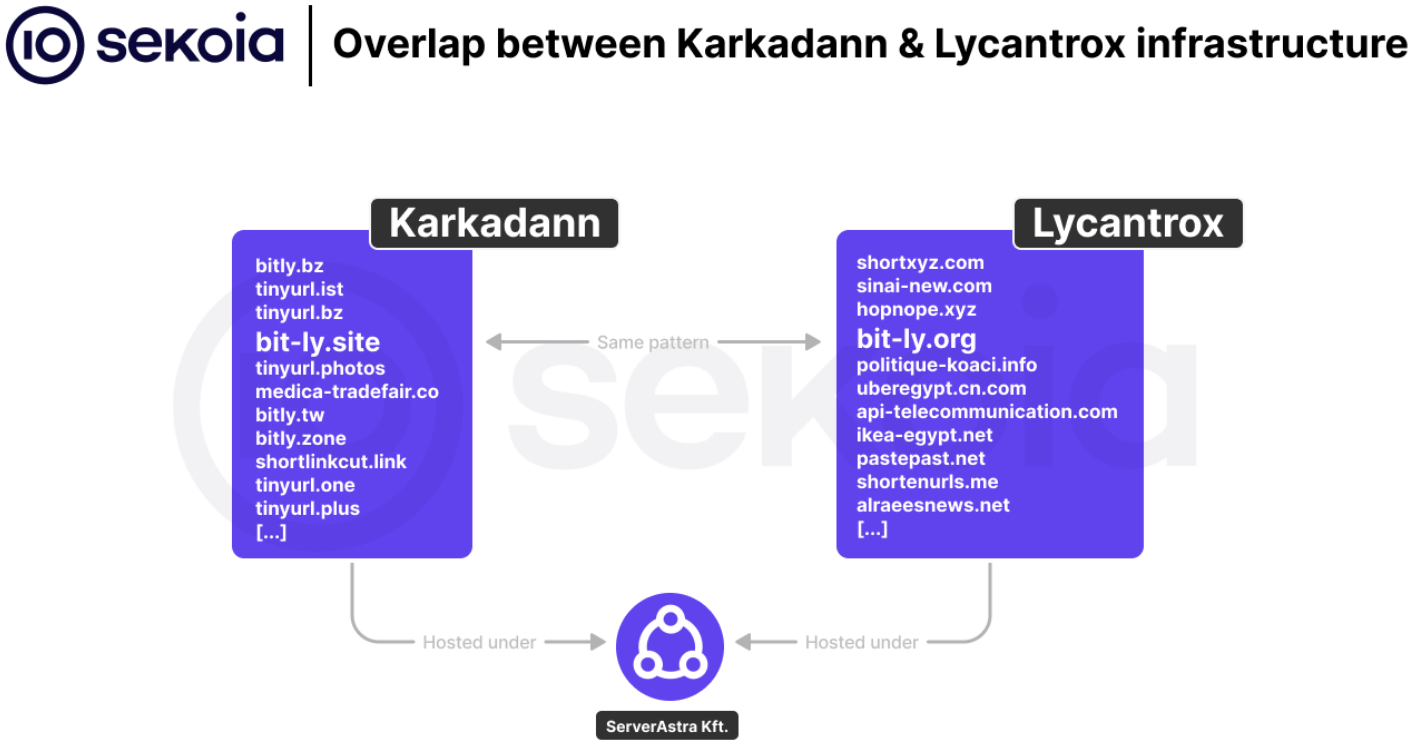
Felix Aimé, Maxime A. and Sekoia TDR
October 2 2023

8 minutes reading

On September 22, Citizenlab published a blog post (https://citizenlab.ca/2023/09/predator-in-the-wires-ahmed-eltantawy-targeted-with-predator-spyware-after-announcing-presidential-ambitions/) regarding the use of **Cytrox's signature Predator spyware** against the iPhone of **the former Egyptian MP Ahmed Eltantawy**. In August and September 2023, Ahmed Eltantawy was targeted via **network-based injection**, redirecting him to malicious web pages when he visited non-HTTPS sites, by exploiting a zero-day exploit chain (CVE-2023-41991 (https://nvd.nist.gov/vuln/detail/CVE-2023-41991), CVE-2023-41992 (https://nvd.nist.gov/vuln/detail/CVE-2023-41992), CVE-2023-41993 (https://nvd.nist.gov/vuln/detail/CVE-2023-41993)) used to install Predator on iOS versions up to 16.6.1.

Cytrox has previously attracted attention for its involvement in the development of its **Predator spyware for targeting civil society**. CitizenLab (https://citizenlab.ca/2021/12/pegasus-vs-predator-dissidents-doubly-infected-iphone-reveals-cytrox-mercenary-spyware/) and META (https://about.fb.com/wp-content/uploads/2021/12/Threat-Report-on-the-Surveillance-for-Hire-Industry.pdf) have released a few blog posts and reports delving into Cytrox and its affiliated cyber intelligence consortium, known as **Intellexa**.

In December 2021, **we issued a FLINT report (https://app.sekoia.io/intelligence/objects/report--e5a2a773-25df-4b51-8e76-e5229232f3c8) exploring potential connections between Cytrox customers** (that we track under the *Lycantrox (https://app.sekoia.io/intelligence/objects/intrusion-set--84110ef0-c7b6-4fc0-8f87-dcfe32eca1d2)* intrusion set) of and **Candiru customers** (tracked under the *Karkadann (https://app.sekoia.io/intelligence/objects/intrusion-set--b840226d-2f5e-474f-8fc3-f2886190f1f5)* intrusion set), prompted by similarities in the infrastructure employed by their respective clientele to compromise their targets. This overlapping infrastructure may stem from shared customers utilizing both Cytrox and Candiru technologies.



SEKOIA.IO is actively monitoring **hundreds of malicious infrastructure clusters** to protect its customers. In light of the recent Citizenlab blogspot and in solidarity with the efforts against

cyber mercenaries, we have chosen to shed light on one of the infrastructure clusters employed by *Lycantrox*, potentially for compromising their targets.

While **the domain patterns look like entry points for exploits kits**, the scale of this infrastructure suggests a broader use of it. However, we lack concrete evidence to confirm this.

Infrastructure illumination

The infrastructure used by the *Lycantrox* consists of **VPS hosted in several autonomous systems**. Each *Lycantrox* user seems to run his own instances of VPS and manage his own domain name related to it. When looking precisely at the services listed on the instances, most of the time there are two open ports, the SSH used for the administration and a 443 managed by Nginx. On several occasions, only the 443 is available.

Unlike most of the C2s listening on 443 out there, **the Nginx instance is configured to answer a certificate only if a valid domain name is provided** to it, otherwise it will answer a `SSL_ERROR_UNRECOGNIZED_NAME_ALERT` and the connexion will be dropped.

To correlate the infrastructure, we can simply get all the IP addresses with the previously disclosed heuristic, looking for VPS with two open ports or less. This will provide us a list of hundreds of IP addresses that we will then be able to check against a passive DNS database in order to grab some domain names to test.

Only by looking at the domain names resolving this list, we can spot a few that ring a bell to us when hunting historically with *Lycantrox* infrastructures such as **fake URL shorteners** or **typosquatting news websites** such as `bitshort[.]info` or `elwatnanews[.]com`. Moreover, many of them are linked to name servers that are known to accept cryptocurrency payments and be associated with cyber criminal activities. However, we need to be sure of their use by *Lycantrox*.

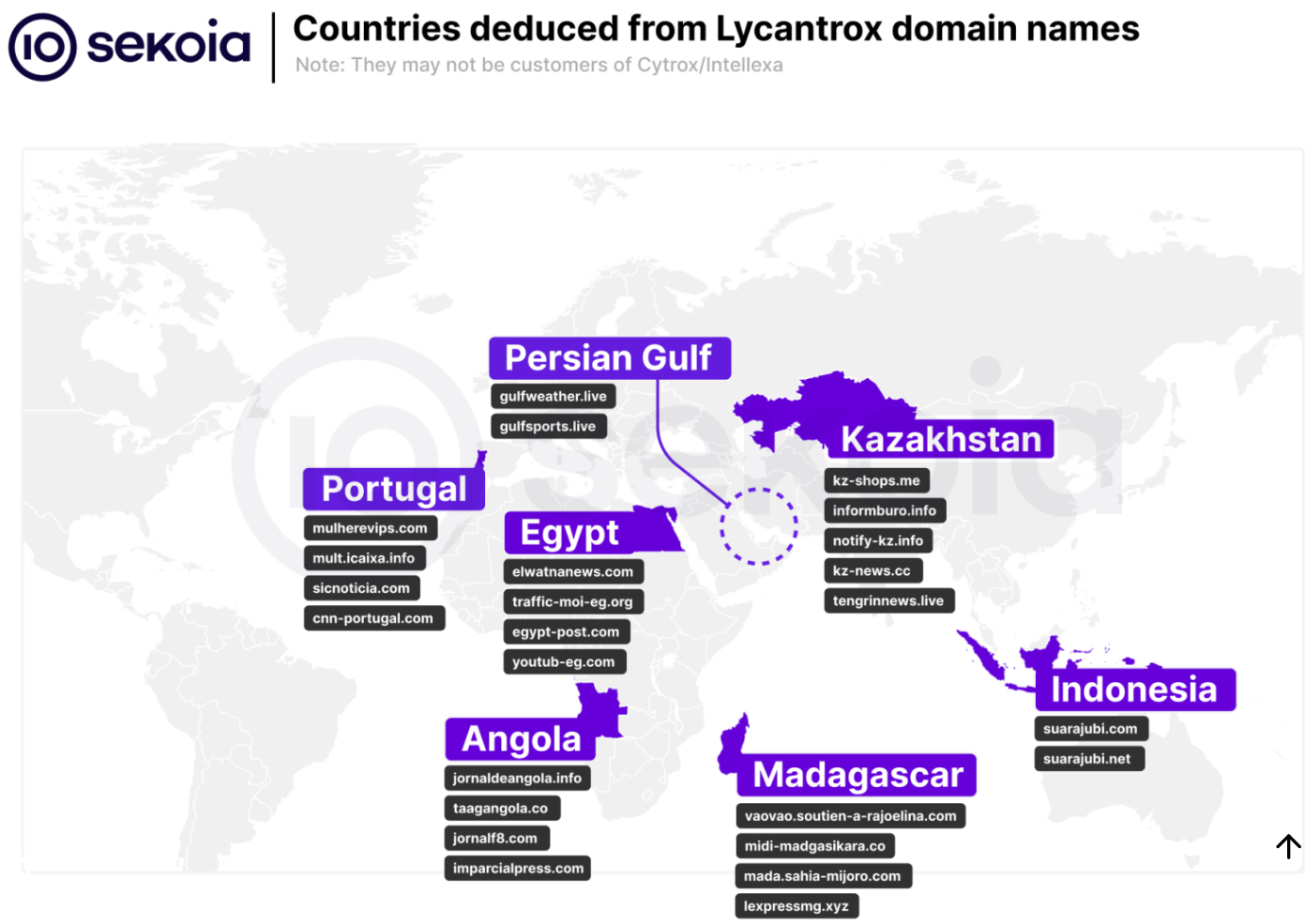
To ensure that the mentioned domains are related to *Lycantrox* infrastructure, an active check can be done. The aim of that is to discover if some of them present anomalies that a default

Nginx installation doesn't show, which will be another discriminant thing to add to our final heuristic. During our investigation we found that the domains answered to any tested URL with a `204 No Content` status code even if they showed a 404 error page, allowing us to categorize each of them, *Lycantrox* related or non-*Lycantrox* related.

At the end, **121 unique active domain names were found** being related with high confidence to an infrastructure cluster linked to the *Lycantrox* intrusion set. Some of the discovered domains typo squat or have few references to specific geographical areas shown in the following map.

We are also providing under "medium confidence" suspected *Lycantrox* related domain names that we haven't been able to check actively during the investigation. **It is worth noting that, by poking around them it's possible to see other domains that might be related to the same threat actors**, possibly used in the past or as backup infrastructure.

Context analysis



Madagascar

The only servers using subdomains pointing to the servers that answered to our heuristic are related to Madagascar. These websites (`soutien-a-rajoelina[.]com`, `emergence-mada[.]com` and `sahia-mijoro[.]com`) – **which seem to have been created by the threat actor itself** – are wordpress blogs containing real articles taken from the Madagascan newspaper Midi Madagasikara, which is also typostatted as `midi-madgasikara[.]co`.

Even if their sub domains are pointing to malicious servers, we haven't been able to detect any malicious iframes, script insertions or fingerprinting scripts leading to the malicious servers on the websites. While looking in open sources for references to these domains, we've seen only one occurrence of `emergence-mada[.]com` – **a post of this blog was linked in a Facebook group supporting the actual president**, Andry Nirina Rajoelina. Sekoia.io was not able to observe malicious content in the history of the linked webpage.

Madagascar is currently campaigning for a **presidential election** on **9 November 2023**, where Rajoelina, current president elected in 2018 is seeking its reelection. Sekoia.io assess it is **plausible Madagascar government services** – such as police or domestic intelligence – did **purchase and leverage Cytrox's Predator** malware to **conduct political domestic surveillance**, months before the election. This hypothesis is politically coherent with Rajoelina's undemocratic approach – 2009 *coup d'etat* getting him in power, 2019 Senat major reform, intense propaganda on social media promoting its reforms. In addition, according to Intelligence Online (https://www.intelligenceonline.fr/surveillance--interception/2023/09/27/nouvel-empire-du-cyber-renseignement-intellexa-glane-les-contrats-delaisses-par-ses-homologues,110057962-art), the company **Intellexa**, Cytrox's parent company, brought from a french company a **contract with the Madagascar government** for the collection and processing of interception data.

Indonesia

Among the *Lycantrox* domains, `suarajubi[.]net` and `suarajubi[.]com` likely typosquat **Jubi TV**, a West Papua province **opposition media** funded by Victor Mambor, journalist and Papuan autonomy activist. Jubi TV (https://www.lowyinstitute.org/the-interpreter/papua-s-journalists-tell-hard-truths-about-local-cronyism-violence) often reports Jakarta operations towards Papuan activists. Sekoia.io assess it is possible **Indonesian intelligence services**

purchased and leverage Cytrox's Predator malware to conduct **political surveillance**, at least on autonomist movements.

Kazakhstan

It is not surprising to see Kazakhstan on that list as this country has a troubled history with cyber surveillance vendors such as NSO (https://www.amnesty.org/en/latest/news/2021/12/kazakhstan-four-activists-mobile-devices-infected-with-pegasus-spyware/), RCS Lab (https://www.lookout.com/threat-intelligence/article/hermit-spyware-discovery) or FinFisher (https://citizenlab.ca/2015/10/mapping-finfishers-continuing-proliferation/) to compromise devices belonging to human right activists, politicians, journalists and opponents (https://cdn.occrp.org/projects/project-p/#/countries/KZ). Based on the *Lycantrox* domains Sekoia.io investigated and on Astana documented use for cyber surveillance tools, **it is likely Kazakhstan** intelligence services **purchased and use Cytrox's Predator** malware.

Angola

Sekoia.io analysts found several domains associated with Angola entities. At least six of them typosquat online medias – `folha-9[.]com`, `factosdiarios[.]co` or `lilpastanews[.]co` – and several others seems related to national entities (the main telecom operator, the national company for oil production, ministry of finance, the national postal service). Sekoia.io found other typosquatted domains associated with Portugal – `mult[.]icaixa[.]info`, `cnn-portugal[.]com` – that we assess as possible part of the Predator campaign in Angola. Given the multiple Angola-related and Portuguese speaking domains, Sekoia.io assess **it is plausible Angola government services were also Cytrox clients**.

Conclusion

It is worth mentioning that *Lycantrox* has hardened its reverse proxies since our previous investigations and after some public disclosures in order to prevent such illumination. However, sometimes, **too much hardening can be discriminatory from a defender point of view**, as we can see with this correlation.

Sekoia.io will continue its efforts against known cyber mercenary threat actors by illuminating their infrastructure and providing for free associated indicators of compromise (IOCs) to the community. Therefore, if you are a **journalist**, **politician** or **human rights activist** we encourage you to check your device for the presence of the following list of domain names, by using, for example **MVT** (https://docs.mvt.re/en/latest/) for analysis of your Android/iOS logs or **SPYGUARD** (https://github.com/SpyGuard) to check in real time your device's network communications against a set of heuristics to detect possible implant beaconing.

Indicators of compromise

Domains mentioned in the CitizenLabs blogpost, also found during our investigation.

```
betly[.]me
sec-flare[.]com
verifyurl[.]me
```

High confidence, active infrastructure during the time of the investigation

```
candidaturasminfin[.]info
grupohel[.]social
notify-kz[.]info
intnews[.]world
taagangola[.]co
afrinew[.]net
tupuca[.]co
newsworldsports[.]co
newspool[.]net
informburo[.]info
dealstransfer[.]net
gorlovski[.]com
egypt-post[.]com
podcastnow[.]club
suarajubi[.]net
suarajubi[.]com
pasteposta[.]com
post-kz[.]info
mada[.]sahia-mijoro[.]com
bbitly[.]com
culniks[.]info
folha-9[.]com
shortly[.]work
lttlnk[.]net
mult[.]icaixa[.]info
mujimbos[.]co
leefco[.]net
liveco[.]live
showsme[.]info
brkorage[.]live
clckbck[.]com
flowercafee[.]com
soq[.]one
jornaldeangola[.]info
geloraku[.]id
smallme[.]net
quick-ads[.]com
jofki[.]com
midi-madgasikara[.]co
flytaps[.]com
factosdiarios[.]co
kz-news[.]cc
```

lilpastanews[.]co
popup-pw[.]info
eventes[.]org
fdnews[.]info
unitei[.]co
businessafricaonline[.]org
breaknews[.]live
actualite[.]emergence-mada[.]com
candidaturassonangol[.]info
correiosdeangola[.]info
9o[.]gg
allafrika[.]live
visavfsglobal[.]co
adenuncia[.]com
portalxa[.]com
sky-news[.]live
vinhosadega[.]com
shop-collect[.]com
bestwesternt[.]com
traffic-moi-eg[.]org
conodeti[.]com
gulfsports[.]info
dw-news[.]co
lexpressmg[.]xyz
jakalas[.]online
t-ready[.]me
grvnews[.]live
air-shopping[.]net
gostosadeluxo[.]com
aoatlasescort[.]com
universedades[.]com
bitshort[.]info
intercontinentalhg[.]com
clubs-k[.]com
nm-weather[.]live
imparcialpress[.]com
blitzmedia[.]live
shanam[.]org
kz-shops[.]me
youtub-eg[.]com
elwatnanews[.]com
lengrinnews[.]live

```
jornalf8[.]com
growebservice[.]com
zoometting[.]com
vaovao[.]soutien-a-rajoelina[.]com
ongs[.]life
truelocation[.]org
ordas-kz[.]com
glbnews[.]live
newsreuter[.]com
novojornal[.]co
almasrylayoum[.]com
dhll[.]live
redirto[.]info
mulherevips[.]com
sicnoticia[.]com
weather-live[.]com
africa-confidentiel[.]fr
skranski[.]com
cnn-portugal[.]com
wesalcity[.]net
platinalines[.]com
onlinewebinarmarketing[.]com
btlin[.]life
tclnk[.]live
kalwaski[.]xyz
sysnet[.]life
clcti[.]net
qamqors[.]net
gorows[.]live
moncn[.]co
skollie[.]online
smcu[.]me
sysly[.]sbs
bulk-ads[.]com
gulfweather[.]live
shortly[.]work
gulfsports[.]live
```

Moderate to high confidence, dormant or inactive infrastructure during the time of the investigation.

↑

```
amritacity[.]com
awlaqf[.]sbs
bosmata[.]com
politi[.]live
toomec[.]net
crudco[.]info
corncog[.]com
dbtest[.]online
espn-sports[.]live
ftlink[.]info
gsxr[.]me
gulfnews[.]today
gulfweather[.]co
helpemail[.]net
isalways[.]net
isconn[.]net
islink[.]info
letmelook[.]one
lnkkdis[.]xyz
lnklit[.]com
mg-news[.]info
miceups[.]com
mncnn[.]info
mnmlink[.]co
pklnk[.]com
post-info[.]kz
previeweb[.]xyz
sexychats[.]nl
southchinapost[.]net
supasports[.]xyz
syscncc[.]live
tconn[.]net
weatherforecast[.]services
```

Thank you for reading this blogpost. We welcome any reaction, feedback or critics about this analysis. Please contact us on tdr[at]sekoia.io

Feel free to read other TDR analysis here :

- Walking on APT31 infrastructure footprints (https://blog.sekoia.io/walking-on-apt31-infrastructure-footprints/)

- Sekoia.io mid-2023 Ransomware Threat Landscape (https://blog.sekoia.io/sekoia-io-mid-2023-ransomware-threat-landscape/)
- Solving the 7777 Botnet enigma: A cybersecurity quest (https://blog.sekoia.io/solving-the-7777-botnet-enigma-a-cybersecurity-quest/)
- XDR detection engineering at scale: crafting detection rules for SecOps efficiency (https://blog.sekoia.io/xdr-detection-rules-at-scale/)
- Sekoia.io CTI at a glance (https://blog.sekoia.io/sekoia-io-cti-at-a-glance/)

APT (https://blog.sekoia.io/tag/apt/) **CTI (https://blog.sekoia.io/tag/cti/)**

Cytrox (https://blog.sekoia.io/tag/cytrox/)

Predator (https://blog.sekoia.io/tag/predator/)

Share this post:

(https://www.facebook.com/sharer/sharer.php?u=https://blog.sekoia.io/active (https://twitter.com/share?text=Active%20Lycantrox%20infrastructure%20illu (https://www.linkedin.com/sharing/share-offsite/?url=https://blog.sekoia.io/active (https://www.reddit.com/submit?url=https://blog.sekoia.io/active-lycan (whatsapp://send?text=Active%20Lycantrox%20infrastructure%20illumination% (tg://msg_url?url=https://blog.sekoia.io/active-lycantrox-infrastructure-illumi (mailto:?subject=Active%20Lycantrox%20infrastructure%20illumination&body=Active%

What's next

(https://blog.sekoia.io/clearfake-a-newcomer-to-the-fake-updates-threats-landscape/)

e-lycantrox-infrastructure-illumination/) mination&url=https://blog.sekoia.io/activity-lycantrox-infrastructure-illumination/) a.io/active-lycantrox-infrastructure-illumination/) trox-infrastructure-illumination/&title=Active%20Lycantrox%20infrastructure%20illumination) 20-ve%20Lycantrox%20infrastructure%20illumination) natio n/) 20Lycantrox%20infrastructure%20illumination%0D%0ASekoia.io%20is%20actively%20monitoring%20hundreds%20of%20malicious%20infrastructure%20clusters%20to%20prote

ClearFake: a newcomer to the "fake updates" threats landscape (https://blog.sekoia.io/clearfake-a-newcomer-to-the-fake-updates-threats-landscape/)

ClearFake is a new malicious JavaScript framework deployed on compromised websites to deliver further malware using the drive-by download...

Quentin Bourgue and Sekoia TDR

(https://blog.sekoia.io/aridviper-an-intrusion-set-allegedly-associated-with-hamas/)

AridViper, an intrusion set allegedly associated with Hamas (https://blog.sekoia.io/aridviper-an-intrusion-set-allegedly-associated-with-hamas/)

Given the recent events involving the Palestinian politico-military organisation Hamas which conducted on 7 October 2023 a military and...

Sekoia TDR

ct%2
0its%
20cu
stom
ers.
%20I
n%20
light
%20o
f%20t
he%2
0rece
nt%2
0Citiz
enlab
%20b
logsp
ot%2
0and
%20i
n%20
solid
arity
%20w
ith%2
0the
%20e
fforts
%20a
gains
t%20
cyber
%20
merc

enari
es%2
C%20
we%2
0hav
e%20
chos
en%2
0to%
20sh
ed%2
0ligh
t%20
on%2
0one
%20o
f%20t
he%2
0infr
astru
cture
%20c
luster
s%20
empl
oyed
%20b
y%20
Lyca
ntrox
%2C
%20p
otent
ially

%20f
or%2
0co
mpro
misin
g%20
their
%20t
arget
s.
%20%
0D%0
A%0D
%0AR
ead%
20mo
re%2
0at%
3A%2
0http
s%3A
%2F%
2Fblo
g.sek
oia.io
%2Fa
ctive
-
lycan
trox-
infras
truct
ure-
illumi

natio

n%2F

)

(https://blog.sekoia.io/game-over-gaming-community-at-risk-with-information-stealers/)

Game Over: gaming community at risk with information stealers (https://blog.sekoia.io/game-over-gaming-community-at-risk-with-information-stealers/)

This report was originally published for our customers on 26 October 2023. The world of online gaming, a thriving...

Marc N. and Sekoia TDR

Comments are closed.

Trending topics

(https://blog.sekoia.io/tag/malware/)

Malware (https://blog.sekoia.io/tag/malware/)

(https://blog.sekoia.io/tag/detection/)

Detection (https://blog.sekoia.io/tag/detection/)

(https://blog.sekoia.io/tag/soc/)

SOC (https://blog.sekoia.io/tag/soc/)

About us

This blog is your trusted source for cutting-edge insights in CTI and SOC. Curated by the Threat Detection & Research team (https://www.sekoia.io/en/about-threat-detection-research-team/) and other experts at Sekoia.io, it is dedicated to empowering cybersecurity professionals, researchers, and enthusiasts with actionable intelligence and industry-leading expertise.
Our mission is simple: to

Tags

7777 botnet (https://blog.sekoia.io/tag/7777-botnet/) APT (https://blog.sekoia.io/tag/apt/) APT28 (https://blog.sekoia.io/tag/apt28/) AWS (https://blog.sekoia.io/tag/aws/) Botnet (https://blog.sekoia.io/tag/botnet/) calisto (https://blog.sekoia.io/tag/calisto/) China (https://blog.sekoia.io/tag/china/) Cloud (https://blog.sekoia.io/tag/cloud/) Compliance (https://blog.sekoia.io/

Categories

Detection Engineering (https://blog.sekoia.io/category/detection-engineering/)

Product News (https://blog.sekoia.io/category/product-news/)

SOC Insights & Other News (https://blog.sekoia.io/category/soc-insights-other-news/)

Threat Research & Intelligence (https://blog.sekoia.io/category/

keep you informed, prepared, and empowered in an ever-evolving cyber threat landscape.

tag/compliance/) CTI (https://blog.sekoia.io/tag/cti/) Cybercrime (https://blog.sekoia.io/tag/cybercrime/) Cybersecurity (https://blog.sekoia.io/tag/cybersecurity/) Dark Web (https://blog.sekoia.io/tag/dark-web/) DDoS (https://blog.sekoia.io/tag/ddos/) Detection (https://blog.sekoia.io/tag/detection/) Detection Engineering (https://blog.sekoia.io/tag/detection-engineering/) DFIR (https://blog.sekoia.io/tag/dfir/) Ecosystem (https://blog.sekoia.io/tag/ecosystem/) EU (https://blog.sekoia.io/tag/eu/) Features (https://blog.sekoia.io/tag/features/) Hackaton (https://blog.sekoia.io/tag/hackaton/) Hacktivism (https://blog.sekoia.io/tag/hacktivism/) Influence (https://blog.sekoia.io/tag/influence/) Infrastructure threat-research/)

(https://blog.sekoia.io/tag/infrastructure/) Integration (https://blog.sekoia.io/tag/integration/) Iran (https://blog.sekoia.io/tag/iran/) Legislation (https://blog.sekoia.io/tag/legislation/) Loader (https://blog.sekoia.io/tag/loader/) Malware (https://blog.sekoia.io/tag/malware/) MSSP (https://blog.sekoia.io/tag/mssp/) Paris2024 (https://blog.sekoia.io/tag/paris2024/) phishing (https://blog.sekoia.io/tag/phishing/) plugx (https://blog.sekoia.io/tag/plugx/) Predator (https://blog.sekoia.io/tag/predator/) Quad7 botnet (https://blog.sekoia.io/tag/quad7-botnet/) Ransomware (https://blog.sekoia.io/tag/ransomware/) Reverse (https://blog.sekoia.io/tag/reverse/) russia (https://blog.sekoia.io/tag/russia/) Sigma (https://blog.sekoia.io/tag/sigma/) SOC (https://blog.sekoia.io/tag/soc/) SOC platform (https://blog.sekoia.io/tag/

soc-platform/) Stealer (https://blog.sekoia.io/tag/stealer/) Strategic (https://blog.sekoia.io/tag/strategic/) ukraine (https://blog.sekoia.io/tag/ukraine/)

XDR (https://blog.sekoia.io/tag/xdr/)

sekoia | blog (https://blog.sekoia.io/)

Cookie Policy (https://www.sekoia.io/en/cookie-policy/) Legal notice (https://www.sekoia.io/en/legal-notice/) Copyright © 2026 Sekoia.io All rights reserved